

Security Testing

Reading: <https://www.geeksforgeeks.org/software-testing-security-testing/>

Brakeman:

<https://github.com/presidentbeef/brakeman>

Brakeman is a static analysis tool that checks Ruby on Rails applications for security vulnerabilities.

1. In Gemfile, add:

```
group :development do
  gem 'brakeman'
end
```

2. To run Brakeman navigate to your project root directory and run the command
“brakeman”

This will generate a report similar to:

```
== Brakeman Report ==

Application Path: /csce431/railsgoat
Rails Version: 4.2.8
Brakeman Version: 5.2.3
Scan Date: 2024-02-09 00:08:52 +0000
Duration: 16.268920147 seconds
Checks Run: BasicAuth, BasicAuthTimingAttack, CSRFTokenFo
ng, ForgerySetting, HeaderDoS, I18nXSS, JRubyXML, JSONEnd
teTableName, Redirect, RegexpDoS, Render, RenderDoS, Rende
athTraversal, StripTags, SymbolDoSCVE, TemplateInjection,

== Overview ==

Controllers: 17
Models: 11
Templates: 27
Errors: 0
Security Warnings: 24

== Warning Types ==

-- press enter/return to continue or q to stop --

Command Injection: 1
Cross-Site Request Forgery: 2
Cross-Site Scripting: 4
Dangerous Send: 1
File Access: 1
Format Validation: 1
Mass Assignment: 2
Path Traversal: 1
Remote Code Execution: 4
SQL Injection: 2
Session Setting: 3
Unmaintained Dependency: 2
```

Note: To output an HTML file, run the following

brakeman -o output.html

3. After Brakeman has finished scanning your application, it will provide a report detailing any security vulnerabilities it has found. The report will categorize the vulnerabilities by severity level (high, medium, low), and it will provide information about each vulnerability, including the file and line number where it was found, as well as recommendations for how to fix it.